

Sprint 1 Static Analysis Report

1. Tools Used

- Programming Languages: JavaScript and JSX, HTML, CSS
- SonarQube: SonarQube Cloud
- Trivy: Version 0.70.0 in the inspected report. Scan type: filesystem dependency vulnerability scan.
- Execution: GitHub Actions CI.

2. Required Metrics

SonarQube

Final dashboard evidence: main branch, commit 64beff05, 308 lines of code, captured September 18, 2026 at 1:42 PM. In the morning, Security has 1 issue, Reliability has 1 issue, and Maintainability has 1 issue, the Quality failed and those issues were fixed and this is the latest dashboard showing all the fixes Passed.

The screenshot displays the SonarQube Cloud interface for the 'music_discovery' project. The top navigation bar includes 'Favorite projects', 'Assigned issues', and 'Explore'. The left sidebar lists navigation options: Overview, Analysis (selected), Issues, Hunter Agent (New), Security hotspots (Deprecated), Architecture, Reporting, Policies, Project, and Administration.

The main content area shows the 'Summary' page for the 'main' branch. It indicates 'Public' visibility, '308 Lines of Code', and a 'Last analysis 1 minute ago' with commit '64beff05'. A green checkmark and 'Passed' status are prominently displayed, along with a 'Quality gate: Sonar way' link. A message states: 'The quality profile assigned to this project has changed. You can explore the change in the Activity page.'

Below this, there are two tabs: 'New Code' and 'Overall Code'. The 'Overall Code' tab is active, showing a grid of metrics:

- Security:** 0 Open issues, Grade A.
- Reliability:** 0 Open issues, Grade A.
- Maintainability:** 0 Open issues, Grade A.
- Accepted Issues:** 0, with a note 'Valid issues that were not fixed'.
- Coverage:** A few extra steps are needed for SonarQube Cloud to analyze your code coverage. Link: 'Set up coverage analysis'.
- Duplications:** 0.0%, with a note 'No conditions set on 336 Lines'.

At the bottom, 'Security Hotspots' (Deprecated) are shown as 0.

2. Required Metrics continued

Trivy

Supplied report commit: bc7ae92457e7c9e26fbb20677865c972fbf1983a. The inspected JSON reports 70 npm packages in package-lock.json.

The screenshot shows a web browser window displaying a Trivy scan summary. The browser's address bar shows 'github.com'. The page has a sidebar on the left with a 'Summary' tab selected. The main content area is titled 'scan summary' and contains the following information:

Trivy dependency scan

Commit: 64beff058fd1a9298d918e6845139795569c68ee
Execution: GitHub Actions (CI)
Scope: filesystem scan of repository dependency manifests/lockfiles
Excluded directories: node_modules, client/dist, .git, .cache

Severity	Count
CRITICAL	0
HIGH	0
MEDIUM	0
LOW	0
UNKNOWN	0

Job summary generated at run-time

Annotations
1 warning and 1 notice

Warning: scan
Node.js 20 is deprecated. The following actions target Node.js 20 but are being forced to run on Node.js 24: actions/checkout@v4, actions/upload-artifact@v4. For more information, see [Show more](#)

Notice: scan
"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see <https://github.com/actions/runner-images/issues/14748>"

3. Scope

SonarQube: Analyzed the Ripple project in asiahkrier/music_discovery on the main branch. The final dashboard reports 308 lines of code. Results cover files included in the configured analysis scope. Custom exclusions: [Verify and enter exclusions from the analysis settings or logs; do not assume none.]

Trivy: Scanned repository dependency manifests and lockfiles for known dependency vulnerabilities. The supplied JSON identifies package-lock.json as the npm scan target. Excluded directories were node_modules, client/dist, .git, and .cache. This was not a container-image scan or a scan of the live Render website.

4. Trend

Baseline sprint — no prior comparison. Within this sprint, earlier SonarQube findings were addressed. The final dashboard reports zero open Security, Reliability, and Maintainability issues and a passing Quality Gate. This is an improvement within the baseline sprint, not a comparison with a previous sprint.

5. Reflection

SonarQube gave us some problems to fix in the morning, but I deleted that dashboard screenshot by mistake, the problems were biography-processing regex performance, nested conditional readability, and GitHub Action commit pinning. These were all fixed and the final SonarQube dashboard shows zero open issues in the displayed categories. Trivy showed no dependency vulnerabilities. Next sprint, we will run both tools on changes and review findings before merging.

Required Statement

This static analysis was generated using automated tools during this sprint.